

Document Title:	CyberTech A.Ş. Olay Müdahalesi Politikası		
Document ID:	CT-POL-003	Version:	01
Status:			
Publish Date:			

CYBERTECH A.Ş.

Bilgi Güvenliği Politikası

Olay Müdahalesi Politikası

Belge No	CT-POL-003
Sürüm	1.0
Yürürlük Tarihi	Nisan 2026
Politika Sahibi	SOC Ekibi / CISO
Onaylayan	CISO / Genel Müdür
Gizlilik	DAHİLİ

1. Amaç

Bu politika, CyberTech A.Ş.'de gerçekleşen veya gerçekleşmesi muhtemel bilgi güvenliği olaylarının tespit edilmesi, sınıflandırılması, müdahale edilmesi ve çözüme kavuşturulması için yapısal bir çerçeve sağlar. Hedefler:

- Güvenlik olaylarının iş etkisini en aza indirmek
- Olay müdahalesini standart, tutarlı ve ölçülebilir hale getirmek
- KVKK, GDPR, ISO 27001 ve BDDK'nın bildirme yükümlülüklerini karşılamak
- Benzer olayların tekrarlanmasını önlemek için sürekli iyileştirme sağlama

Document Title:	CyberTech A.Ş. Olay Müdahalesi Politikası		
Document ID:	CT-POL-003	Version:	01
Status:			
Publish Date:			

2. Kapsam

Bu politika; şirkete ait tüm sistemleri, ağları, uygulamaları ve verileri etkileyen aşağıdaki olay türlerini kapsar:

Olay Kategorisi	Örnekler
Siber Saldırı	DDoS, ransomware, APT, kimlik avı, brute-force
Veri İhlali	Yetkisiz veri erişimi, sızıntı, kişisel veri ifşası
Sistem/Hizmet Kesintisi	Kritik sistem arızası, fidye yazılımı kaynaklı kesinti
İçeriden Tehdit	Yetkisiz veri kopyalama, sabotaj, ayrıcalık kötüye kullanımı
Kötü Amaçlı Yazılım	Virüs, trojan, ransomware, spyware enfeksiyonu
Fiziksel Güvenlik	Ekipman hırsızlığı, yetkisiz fiziksel erişim

3. Olay Sınıflandırması

Seviye	Sınıf	Tanım	Müdahale Süresi	Eskalasyon
P1	KRİTİK	Kritik sistem çöküşü, aktif veri sızıntısı, fidye yazılımı, üretim kaybı	≤ 15 dakika	CISO & GM
P2	YÜKSEK	Önemli sistem etkisi, potansiyel veri ifşası, başarılı kimlik hırsızlığı	≤ 1 saat	CISO
P3	ORTA	Sınırlı etki, brute-force girişimi, kötü amaçlı yazılım tespiti	≤ 4 saat	SOC Yöneticisi
P4	DÜŞÜK	Minimal etki, politika ihlali, şüpheli aktivite, izleme anomalisi	≤ 24 saat	SOC Analisti

Document Title:	CyberTech A.Ş. Olay Müdahalesi Politikası		
Document ID:	CT-POL-003	Version:	01
Status:			
Publish Date:			

4. Olay Müdahale Ekibi (CSIRT)

Rol	Sorumluluk	İletişim	Yedek
CISO (Olay Komutanı)	Genel koordinasyon, eskalasyon, dış bildirimler	7/24 ulaşılabilir	Genel Müdür
SOC Analisti (L1)	İlk triage, ilk müdahale, log analizi	Vardiya sistemi	L2 Analist
SOC Analisti (L2)	Derinlemesine analiz, adli inceleme, raporlama	İş saatleri + çağrı	CISO
IT Altyapı Uzmanı	Sistem izolasyonu, kurtarma, hardening	7/24 çağrı	IT Yöneticisi
Hukuk Danışmanı	Yasal yükümlülükler, KVKK bildirimleri	İş saatleri	Dış hukuk firması
İK / İletişim	İç iletişim, çalışan bildirimleri	İş saatleri	GM Sekreteri

5. NIST SP 800-61R2 Olay Müdahale Yaşam Döngüsü

5.1 Hazırlık

Olay müdahalesine hazır olmak için yürütülen sürekli faaliyetler:

- Wazuh SIEM sisteminin yapılandırılması ve özel uyarı kurallarının tanımlanması
- Olay müdahale playbook'larının hazırlanması ve düzenli güncellenmesi
- CSIRT ekibinin tatbikat ve simülasyonlarla eğitilmesi (yılda en az 2 kez)
- İletişim planı ve eskalasyon matrisinin güncel tutulması
- Yedekleme ve kurtarma sistemlerinin düzenli test edilmesi
- Forensik araç seti ve güvenli iletişim kanallarının hazır tutulması

Document Title:	CyberTech A.Ş. Olay Müdahalesi Politikası		
Document ID:	CT-POL-003	Version:	01
Status:			
Publish Date:			

5.2 Tespit ve Analiz (Detection & Analysis)

Olayların tespit edilmesi ve doğrulanması:

- Wazuh SIEM, IDS/IPS, güvenlik duvarı loglarından otomatik uyarı alınır
- Kullanıcı veya sistem bildirimleri alınır
- SOC analisti uyarıyı triage eder, false positive/true positive tespiti yapılır
- Olay Ciddiyet Sınıflandırması (P1-P4) uygulanır
- Olay kaydı açılır: Olay ID, tarih/saat, kaynak, etkilenen sistemler, ilk bulgular
- Eğer P1 veya P2 ise CISO derhal bilgilendirilir

5.3 Karantinaya Alma, Silme & Kurtarma (Containment, Eradication & Recovery)

Kısa Vadeli Karantina (İlk 15 dakika: P1 için)

- Etkilenen sistemlerin ağdan izolasyonu (fiziksel veya VLAN izolasyonu)
- Saldırı kaynağı IP adreslerinin güvenlik duvarında engellenmesi
- Ele geçirilmiş hesapların kilitlenmesi ve parola sıfırlama
- Kritik sistemlerin anlık yedeğinin alınması (forensik kanıt için)

Uzun Vadeli Karantina

- Kötü amaçlı yazılım veya saldırı vektörünün tespiti ve belgelenmesi
- Etkilenen sistemlerin forensik imajının alınması (kanıt muhafazası)
- Güvenlik açığının yamalanması veya geçici kontrol uygulanması

Silme (Eradication)

- Kötü amaçlı yazılım, arka kapı ve yetkisiz erişim noktalarının temizlenmesi
- Ele geçirilmiş kimlik bilgilerinin tüm sistemlerde geçersiz kılınması
- Zafiyetin kapatılması (patch, yapılandırma değişikliği veya servis kapatma)

Kurtarma (Recovery)

- Sistemlerin temiz yedekten veya yeniden kurulum ile geri getirilmesi
- Güçlendirilmiş güvenlik yapılandırmasıyla yeniden hizmete alma
- Sistemin belirli bir süre yoğun izleme altında tutulması
- Kullanıcıların bilgilendirilmesi ve parola sıfırlamalarının tamamlanması

Document Title:	CyberTech A.Ş. Olay Müdahalesi Politikası		
Document ID:	CT-POL-003	Version:	01
Status:			
Publish Date:			

5.4 Olay Sonrası Değerlendirme (Post-Incident Activity)

- Olay sonrası toplantı (After-Action Review): olaydan en geç 5 iş günü içinde
- Zaman çizelgesi ve kök neden analizinin (RCA) tamamlanması
- Lessons Learned raporunun hazırlanması
- Politika, prosedür ve teknik kontrollerin iyileştirilmesi
- Olay kaydının kapatılması ve arşivlenmesi

6. Yasal Yükümlülükler

Düzenleme	Yükümlülük	Süre
KVKK	Kişisel Verileri Koruma Kurumu (KVKK)	72 saat içinde (kişisel veri ihlalinde)
GDPR	İlgili AB Denetim Otoritesi (AB müşterileri)	72 saat içinde
BDDK	Bankacılık Düzenleme ve Denetleme Kurumu	Derhal ilk tespitte
MASAK	Mali Suçları Araştırma Kurulu	Şüpheli işlem tespitinde derhal

7. İletişim Prosedürü

7.1 İç İletişim

- Güvenlik olayı bildirimleri şifreli e-posta veya güvenli mesajlaşma kanalı üzerinden iletilir
- Olay ayrıntıları standart kurumsal iletişim kanallarında (Teams, e-posta) tartışılmaz
- Çalışanlara 'bilmesi gereken' ilkesiyle bilgilendirme yapılır

7.2 Dış İletişim

- Medya ve kamuoyu açıklamaları: Yalnızca Genel Müdür veya yetkilendirdiği sözcü
- Müşteri bildirimleri: Hukuk Danışmanı onayıyla CISO koordinasyonunda
- Kolluk bildirimleri: CISO ve Hukuk Danışmanı birlikte

Document Title:	CyberTech A.Ş. Olay Müdahalesi Politikası		
Document ID:	CT-POL-003	Version:	01
Status:			
Publish Date:			

8. Kanıt Toplama ve Adli İnceleme

- Tüm dijital kanıtlar orijinal haliyle korunur (sistemler formatlanmadan önce snapshot alınır)
- Log dosyaları değiştirilmeden ve bütünlük doğrulaması yapılarak arşivlenir
- Kanıt muhafaza zinciri (Chain of Custody) belgelenir
- Adli inceleme için harici uzman desteği alınabilir
- Kolluk soruşturması ihtimaline karşı tüm kanıtlar en az 5 yıl saklanır

9. Eğitim ve Tatbikat

- Tüm CSIRT üyeleri yılda en az 1 kez olay müdahale eğitimi alır
- Masa başı tatbikatı (Tabletop Exercise): Yılda 2 kez
- Tam ölçekli simülasyon: Yılda 1 kez
- Yeni güvenlik açıkları için reaktif eğitimler düzenlenir

9. Politika Revizyonu ve İyileştirme

Bu politika aşağıdaki takvimde gözden geçirilir:

Gözden Geçirme Sıklığı	Yıllık veya her büyük olay sonrasında
Sorumlu	SOC Ekibi ve CISO
Son Revizyon	Nisan 2026
Sonraki Revizyon	Nisan 2027
Ek Belgeler	